

Cisco Secure Workload — NIS2 Compliance Mapping

Customer Compliance Report

Cisco Secure Workload — Compliance Mapping Series

Table of Contents

Cisco Secure Workload — NIS2 Compliance Mapping

Customer: [Customer Name] **Prepared:** [Month Year] **Standard:** Directive (EU) 2022/2555 — NIS2 **Transposition deadline:** 17 October 2024 **Document type:** Customer-facing compliance mapping

How to read this report

This is a *control mapping*, not a certification. NIS2 is implemented through national law in each Member State, which can add or refine requirements. For each Article 21(2) measure and the Article 23 reporting flow, the report identifies how Cisco Secure Workload (CSW) capabilities can be used to produce evidence of the underlying measure, what that evidence looks like in practice, and where complementary controls or governance work remain the responsibility of the in-scope entity.

Three pages to anchor on:

1. **Executive Summary** — what NIS2 expects, where CSW fits, where it does not.
2. **Compliance Posture Summary** — the at-a-glance measure-by-measure table. Replace the *Status* column with your own scope before sharing externally.
3. **Mapping Table** — measure-by-measure view linking Article 21(2) provisions to specific CSW capabilities and the artefact that demonstrates each.

For implementation steps, sample policies, and the auditor response playbook, see the companion [Technical Runbook](#).

How to read the coverage words

Full Coverage on the older reports means Secure Workload can produce that row's artifact. It does not mean the control is met.

Partial Coverage means file that export next to another control.

Evidence Required means Secure Workload has no record. The customer files the contract, the analysis, or the HR or physical-security evidence.

Direct, Supporting, and Out of scope on the newer reports are the same idea in different words. Direct is still evidence, not a pass.

1. Executive Summary

NIS2 (Directive (EU) 2022/2555) replaces the original Network and Information Security Directive and applies, via national transposition, to a much broader set of sectors than NIS1. It introduces:

- A **two-tier scope** — essential entities and important entities, with different supervisory regimes and fine ceilings.
- A **measure-based risk-management framework** in Article 21(2) (ten measures, listed below).
- A **harmonised reporting flow** in Article 23 (24-hour early warning, 72-hour notification, 1-month final report).
- **Management-body accountability** in Article 20 with personal liability and a training obligation.

Where CSW is most relevant. CSW is most directly relevant to:

- Article 21(2)(a) — *risk-analysis & IS-security policies*: as the enforcement and verification layer that turns policy into observable workload behaviour.
- Article 21(2)(b) — *incident handling*: as the workload-resident detection, telemetry, and forensic engine.
- Article 21(2)(d) — *supply chain security*: as the technical view of what your in-scope workloads are actually doing with each of your direct suppliers' endpoints.
- Article 21(2)(e) — *security in acquisition / development / maintenance, including vulnerability handling*: as the workload vulnerability inventory and CVE-to-attack-path engine.
- Article 21(2)(f) — *effectiveness assessment*: as the source of the quarterly operating-effectiveness metrics the management body reviews under Article 20.
- Article 21(2)(i) — *asset management* part of HR / access / asset management: as the continuous workload inventory baseline.
- Article 21(2)(j) — *secured workload-to-workload communication* analogue: through identity- and label-based segmentation.
- Article 23 — *reporting*: as the source of the 6-artefact evidence pack that supports all three reporting deadlines.

Where CSW supports but does not solve. CSW does not provide backup/recovery primitives (Art. 21(2)(c)), cryptographic primitives (Art. 21(2)(h)), MFA (Art. 21(2)(j) authentication portion), or training (Art. 21(2)(g)). These are addressed by other parts of the Cisco Security portfolio (Duo, ISE, Umbrella) and by the entity's own programme.

2. Compliance Posture Summary

Replace the *Status* column with the customer's own scope and deployment stage before sharing externally. The default reflects a mid-stage CSW deployment with most in-scope services labelled and at least one service in enforced segmentation.

Article 21(2) Measure	CSW Coverage	Status
(a) Risk-analysis & IS-security policies	Workspace Intents, Simulation → Enforce, exception register	Fully addressed (with policy authoring effort)
(b) Incident handling	Detection rules + SIEM forwarding + 6-artefact dossier	Fully addressed
(c) Business continuity / backups / crisis	Containment + forensic preservation only	Out of scope (backup/recovery)
(d) Supply chain security	Supplier egress reconciliation + enforcement	Fully addressed (technical lens)
(e) Sec. acquisition / dev / maintenance + vuln handling	Vulnerability inventory + CI/CD gate + CVE-to-attack-path	Fully addressed
(f) Effectiveness assessment	Quarterly effectiveness pack	Fully addressed
(g) Cyber hygiene + training	Patch & process telemetry; training out of scope	Supports (training out of scope)
(h) Cryptography / encryption	Plaintext-protocol DENY enforcement	Supports (no crypto primitives)
(i) HR sec / access control / asset management	Continuous inventory + label discipline	Fully addressed (asset-mgmt portion)
(j) MFA / secured comms	Identity-based segmentation (workload-to-workload analogue)	Supports (MFA out of scope)
Article 23 reporting (24h / 72h / 1mo)	6-artefact dossier supporting all three phases	Fully addressed (technical evidence)
Article 20 management-body accountability	Quarterly NIS2 pack	Supports (governance is customer-owned)

3. Mapping Table — NIS2 Provision → CSW Capability → Evidence Artefact

Provision	Requirement (paraphrased)	CSW capability	Evidence artefact
Art. 20(1)	Management body accountability	Quarterly NIS2 pack	Pack PDF
Art. 20(2)	Management body	Pack section	Reusable training

Provision	Requirement (paraphrased)	CSW capability	Evidence artefact
	training	commentary	material
Art. 21(2)(a)	Risk analysis & IS-security policies	Workspace Intents grounded in observed behaviour	Workspace export
Art. 21(2)(b)	Incident handling	Detection rules + SIEM forwarding	Rule catalogue, SIEM config
Art. 21(2)(c)	Business continuity / backup / crisis	Containment policy + forensic preservation	Quarantine evidence
Art. 21(2)(d)	Supply chain security	Supplier egress reconciliation	Register-vs-observed delta
Art. 21(2)(e)	Sec. acquisition / dev / maintenance + vuln handling	Vulnerability inventory + CI/CD gate	CVE-to-attack-path report
Art. 21(2)(f)	Effectiveness assessment	Quarterly effectiveness pack	Effectiveness pack PDF
Art. 21(2)(g)	Cyber hygiene + training	Patch & process telemetry	Patch posture report
Art. 21(2)(h)	Cryptography / encryption	Plaintext-protocol DENY enforcement	Policy export
Art. 21(2)(i)	HR sec / access control / asset management	Continuous workload inventory + label discipline	Inventory export, label coverage trend
Art. 21(2)(j)	MFA / secured comms	Identity-based segmentation	Segmentation workspace export
Art. 23(1)	24-h early warning	6-artefact dossier (initial)	Time-stamped evidence bundle
Art. 23(2)	72-h notification	Same dossier (progressive)	Updated evidence bundle
Art. 23(3)	1-month final report	Same dossier + RCA & remediation	Final dossier
Art. 32 / 33	Supervisory information requests	On-demand exports	Audit-ready CSV/PDF

4. Out-of-Scope and Complementary Controls

The following NIS2 areas are intentionally not addressed by CSW. They are listed here so the entity's compliance programme can confirm coverage from other tools or processes:

- **Article 20 management-body governance and training** — process and curriculum outside CSW.

- **Article 21(2)(c) backup, recovery and crisis management primitives** — backup/recovery tooling outside CSW.
 - **Article 21(2)(g) cybersecurity training** — addressed by awareness platforms.
 - **Article 21(2)(h) cryptography primitives** — provided by the entity's PKI, KMS, and operating systems.
 - **Article 21(2)(j) MFA itself** — addressed by Cisco Duo or equivalent.
 - **National-law additions and supervisory regime specifics** — addressed by the entity's compliance counsel and the relevant competent authority.
-

5. Suggested Next Steps

1. Confirm the entity's NIS2 classification (essential vs. important) and the in-scope service list.
 2. Pick one in-scope service to take through the full simulation → enforce cycle and produce a worked example of the §3 evidence artefacts.
 3. Schedule the quarterly NIS2 pack to precede the management body's risk review meeting (Art. 20).
 4. Wire the 6-artefact incident dossier into the SOC's incident- response runbook so the 24-hour early warning is automatic, not reactive.
 5. Engage the Cisco account team for a scoping discussion if any of the *Status* column entries above need adjustment for the entity's actual deployment stage.
-

6. Disclaimer

This document describes how Cisco Secure Workload product capabilities can support a NIS2 programme. It is **not** legal, regulatory, or audit advice. NIS2 is implemented through Member State law that may add or refine requirements; classification as essential vs. important, incident significance thresholds, supplier-related obligations, and applicable fines are determined by your own management body and qualified counsel, working with the relevant national competent authority and CSIRT. Always validate against the latest implementing acts, ENISA guidance, and Member State transposition before formal use.

For questions or to validate how this mapping applies to your specific environment, contact your **Cisco account team**.